

CNO IV (T37A): Seguridad Informática

Mtro. Servando López Contreras

AGOSTO 2026						
D	L	M	M	J	V	S
						1
2	3	4	5	6	7	8
9	10	11	12	13	14	15
16	17	18	19	20	21	22
23	24	25	26	27	28	29
30	31					

SEPTIEMBRE 2026						
D	L	M	M	J	V	S
		1	2	3	4	5
6	7	8	9	10	11	12
13	14	15	16	17	18	19
20	21	22	23	24	25	26
27	28	29	30			

OCTUBRE 2026						
D	L	M	M	J	V	S
				1	2	3
4	5	6	7	8	9	10
11	12	13	14	15	16	17
18	19	20	21	22	23	24
25	26	27	28	29	30	31

NOVIEMBRE 2026						
D	L	M	M	J	V	S
1	2	3	4	5	6	7
8	9	10	11	12	13	14
15	16	17	18	19	20	21
22	23	24	25	26	27	28
29	30					

DICIEMBRE 2026						
D	L	M	M	J	V	S
		1	2	3	4	5
6	7	8	9	10	11	12
13	14	15	16	17	18	19
20	21	22	23	24	25	26
27	28	29	30	31		

ENERO 2027						
D	L	M	M	J	V	S
				1	2	
3	4	5	6	7	8	9
10	11	12	13	14	15	16
17	18	19	20	21	22	23
24	25	26	27	28	29	30
31						

FEBRERO 2027						
D	L	M	M	J	V	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28						

MARZO 2027						
D	L	M	M	J	V	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30	31			

ABRIL 2027						
D	L	M	M	J	V	S
				1	2	3
4	5	6	7	8	9	10
11	12	13	14	15	16	17
18	19	20	21	22	23	24
25	26	27	28	29	30	

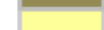
MAYO 2027						
D	L	M	M	J	V	S
						1
2	3	4	5	6	7	8
9	10	11	12	13	14	15
16	17	18	19	20	21	22
23	24	25	26	27	28	29
30	31					

JUNIO 2027						
D	L	M	M	J	V	S
		1	2	3	4	5
6	7	8	9	10	11	12
13	14	15	16	17	18	19
20	21	22	23	24	25	26
27	28	29	30			

JULIO 2027						
D	L	M	M	J	V	S
				1	2	3
4	5	6	7	8	9	10
11	12	13	14	15	16	17
18	19	20	21	22	23	24
25	26	27	28	29	30	31

-  INICIO DE SEMESTRE
-  LÍMITE PARA BAJA DE MATERIA
-  EXÁMENES PARCIALES
-  EXÁMENES FINALES
-  EXÁMENES EXTRAORDINARIOS
-  EXÁMENES DE REGULARIZACIÓN

-  DÍAS FESTIVOS
-  LÍMITE PARA ACREDITAR LA RESIDENCIA PROFESIONAL
-  FIN DE SEMESTRE
-  EGEL
-  LÍMITE PARA BAJA TEMPORAL Y ALTA DE RESIDENCIA PROFESIONAL

-  RECESO ACADÉMICO
-  INSCRIPCIÓN CURSOS DE VERANO
-  CURSOS DE VERANO
-  CEREMONIAS DE TITULACIÓN
-  SELECCIÓN DE HORARIOS

PARCIALES



Fundamentos de
ciberseguridad



Sistemas de gestión de la
seguridad



Temas actuales en
seguridad informática

FORMA DE EVALUACIÓN

PROYECTO P1

De la teoría a la práctica: walkthrough en acción (guía y video).

PROYECTO P2

Blindando la información: gobernanza y cumplimiento.

PROYECTO P3

La memoria del crimen: análisis forense digital.

	PARCIAL I	PARCIAL II	PARCIAL III	EVALUACIÓN ORDINARIA	EVALUACIÓN EXTRAORDINARIA	EVALUACIÓN DE REGULARIZACIÓN
Actividades	60	60	60	Portafolio digital (100%)	-	-
Proyecto	30	30	30		-	-
Examen	10	10	10		100	100
TOTAL (%)	100	100	100		100	100

Fechas de examen:

Parcial I: martes 08 de septiembre de 2026.

Parcial II: martes 13 de octubre de 2026.

Parcial III: martes 24 de noviembre de 2026.

Final: martes 01 de diciembre de 2026 (por confirmar).

ET: martes 08 de diciembre de 2026 (por confirmar).

ER: martes 15 de diciembre de 2026 (por confirmar).

El **portafolio digital** constituye el compendio integral de las *actividades, prácticas y proyectos desarrollados por el estudiante a lo largo de la asignatura*.

Su finalidad es documentar de manera estructurada y sistemática el proceso de aprendizaje, así como las competencias técnicas adquiridas en materia de seguridad informática.

El portafolio integra ejercicios prácticos de pruebas de penetración, análisis de vulnerabilidades, uso y documentación de herramientas especializadas, evidencias audiovisuales (videos demostrativos) y resultados obtenidos durante el curso. Asimismo, permite reflejar la capacidad del estudiante para organizar, comunicar y presentar información técnica de forma profesional.

El portafolio deberá desarrollarse y publicarse en una plataforma digital, preferentemente mediante **repositorios en GitHub** o a través de un **desarrollo web nativo**, garantizando accesibilidad, orden, claridad y buenas prácticas de documentación.

Estructura mínima general:

- **Inicio.**
- **Notas.**
- **Herramientas.**
- **Proyectos.**
- **Certificados.**

Sistema de calificaciones:

Aprobatorio: ≥ 7.0

Acreditar una asistencia no menor a las dos terceras partes del período que comprende el examen.

Redondeo de decimales: 7.3 = 7.0
7.4 = 7.5

1.4 = 1

1.5 = 1

1.8 = 1

6.9 = 6

7.5 = 7.5

7.8 = 7.5

7.9 = 8.0

TIPOS DE MALWARE



ADWARE

El adware a menudo se instala con algunas versiones de software y está diseñado para **entregar automáticamente anuncios a un usuario**, la mayoría de las veces en un navegador web. ¡Lo sabes cuando lo ves! Es difícil ignorarlo cuando te enfrentas a anuncios emergentes constantes en tu pantalla.

Es común que el adware venga con spyware.



TIPOS DE MALWARE



BACKDOOR

Este tipo de malware se utiliza para **obtener acceso no autorizado al omitir los procedimientos de autenticación normales para acceder a un sistema**. Como resultado, los hackers pueden obtener acceso remoto a los recursos de una aplicación y emitir comandos remotos del sistema.

Una puerta trasera funciona en segundo plano y es difícil de detectar.



TIPOS DE MALWARE



RANSOMWARE

El malware está diseñado para mantener cautivo un sistema computacional o los datos que contiene hasta que se realice un pago. El ransomware generalmente funciona

cifrando sus datos para que no pueda acceder a ellos.

Algunas otras versiones de ransomware pueden aprovechar vulnerabilidades específicas del sistema para bloquearlo. El ransomware a menudo se propaga a través de correos electrónicos de phishing que lo alientan a descargar un archivo adjunto malicioso o a través de una vulnerabilidad.



ANATOMÍA DE UN RANSOMWARE

01 Punto de entrada

Es la parte donde inicia el programa: importa librerías, define variables globales y llama a la función principal.

Librería	Capacidad técnica	Uso legítimo	Riesgo en análisis
os	Acceso a sistema de archivos, variables de entorno	Scripts, automatización	Enumeración de archivos, fingerprinting
pathlib	Manejo estructurado de rutas	Apps modernas	Recorrido de archivos objetivo
shutil	Copiar, mover, eliminar archivos	Backups, gestión de archivos	Persistencia, propagación
subprocess	Ejecutar comandos del sistema	Administración	Ejecución de comandos del SO
platform	Información del sistema	Diagnóstico	Detección de VM/sandbox
sys	Control de ejecución, argumentos	Scripts CLI	Manipulación del flujo
psutil	Información de procesos y sistema	Monitoreo	Enumeración de procesos (anti-análisis)
time	Control de tiempo, delays	Automatización	Evasión por sleep
threading	Ejecución concurrente	Apps multihilo	Paralelización de acciones
requests	HTTP/HTTPS	APIs	Comunicación externa (C2)
socket	Comunicación de bajo nivel	Networking	Canales ocultos de comunicación
urllib	Manejo de URLs	Descargas	Descarga de payloads
hashlib	Hashing	Seguridad	Integridad o preparación de datos
cryptography	Cifrado avanzado	Seguridad real	Transformación de archivos (núcleo ransomware)
base64	Codificación	Transporte de datos	Ofuscación de código
codecs	Codificación/decodificación	Texto	Ocultamiento de payloads

ANATOMÍA DE UN RANSOMWARE

02 Configuración interna

Suelen declararse rutas, extensiones objetivo, nombres de archivo, notas de rescate, exclusiones o banderas internas.

```
CONFIG = {  
    "target_extensions": [  
        ".docx", ".xlsx", ".pdf", "<warning:otras_extensioes>"  
    ],  
    "excluded_paths": [  
        "<warning:rutas_sensibles_del_sistema>"  
    ],  
    "note_name": "<warning:nombre_de_nota>",  
    "marker": "<warning:identificador_interno>"  
}
```

03 Validación del entorno

Muchos códigos maliciosos revisan si están siendo analizados o si el entorno no les conviene.

```
def check_environment():  
    <warning:detectar_maquina_virtual>  
    <warning:detectar_debugger>  
    <warning:detectar_sandbox>  
    <warning:detectar_privilegios>
```

ANATOMÍA DE UN RANSOMWARE

04 Persistencia

Bloque destinado a que el programa sobreviva a reinicios o vuelva a ejecutarse.

```
def establish_persistence():  
    <warning:modificar_inicio_automatico>  
    <warning:copiarse_a_ruta_persistente>  
    <warning:crear_tarea_programada>
```

05 Descubrimiento de archivos y rutas

El ransomware necesita localizar los archivos que le interesan.

```
def discover_files(base_path):  
    files_found = []  
    for item in <warning:recorrer_directorios>:  
        if <warning:extension_objetivo> and not <warning:ruta_excluida>:  
            files_found.append(item)  
    return files_found
```

ANATOMÍA DE UN RANSOMWARE

06 Preparación criptográfica

Cómo genera, obtiene o maneja claves.

```
def setup_crypto():  
    <warning:generar_clave>  
    <warning:proteger_clave>  
    <warning:almacenar_o_transmitir_material_criptografico>
```

07 Encriptación

```
def process_file(file_path, crypto_context):  
    data = <warning:leer_archivo>  
    transformed_data = <warning:aplicar_transformacion_criptografica>  
    <warning:sobrescribir_o_guardar_nueva_version>  
    <warning:renombrar_archivo>
```

08 Manejo de nombres y extensiones

```
def rename_artifact(file_path):  
    new_name = file_path + "<warning:nueva_extencion>"  
    <warning:renombrar_archivo_en_disco>
```


TIPOS DE MALWARE



SCAREWARE

Este es un tipo de malware que utiliza tácticas de «miedo» para engañarlo para que tome una acción específica. El scareware consiste principalmente en **ventanas emergentes que aparecen para advertirle que su sistema está en riesgo y necesita ejecutar un programa específico** para que vuelva a funcionar normalmente.

Si acepta ejecutar el programa específico, su sistema se infectará con malware.



Your phone has (13)serious virus

We noticed that your browser is damaged (28.1%), it has (13) dangerous viruses from porn sites, and your SIM card will be damaged, as well as your contacts, photos, information.



2 minutes and 45 seconds.

If you do not install uc browser, your phone will be severely damaged.

Below are instructions on how to get rid of this problem (Step by Step):

Step 1: Click the button to install the free uc browser from the Google play store!

Step 2: Open the application, hence it can shield all the viruses when you are browsing the web.

Now shield all the viruses



TIPOS DE MALWARE



ROOTKIT

Este malware está diseñado para **modificar el sistema operativo** para crear una puerta trasera, que los atacantes pueden usar para acceder a su computadora de forma remota. La mayoría de los rootkits aprovecha las vulnerabilidades de software para ganar acceso a recurso que normalmente no debería ser accesibles (escalada de privilegios) y modificar los archivos del sistema.

Los rootkits también pueden modificar las herramientas de monitoreo y análisis forense del sistema, lo que los hace muy difíciles de detectar. En la mayoría de los casos, un equipo infectado por un rootkit debe borrarse y reinstalarse cualquier software necesario.



TIPOS DE MALWARE VIRUS



Un virus es un tipo de programa informático que, **cuando se ejecuta, se replica** y se adjunta a otros archivos ejecutables, como un documento, insertando su propio código. La mayoría de los virus requieren la interacción del usuario final para iniciar la activación y se pueden escribir para que actúen en una fecha u hora específica.

Los virus pueden ser relativamente inofensivos, como los que muestran una imagen divertida. O pueden ser destructivos, como los que modifican o eliminan datos.

Los virus también pueden programarse para mutar a fin de evitar la detección. La mayoría de los virus ahora se esparcen por unidades USB, discos ópticos, recursos de red compartidos o correo electrónico.



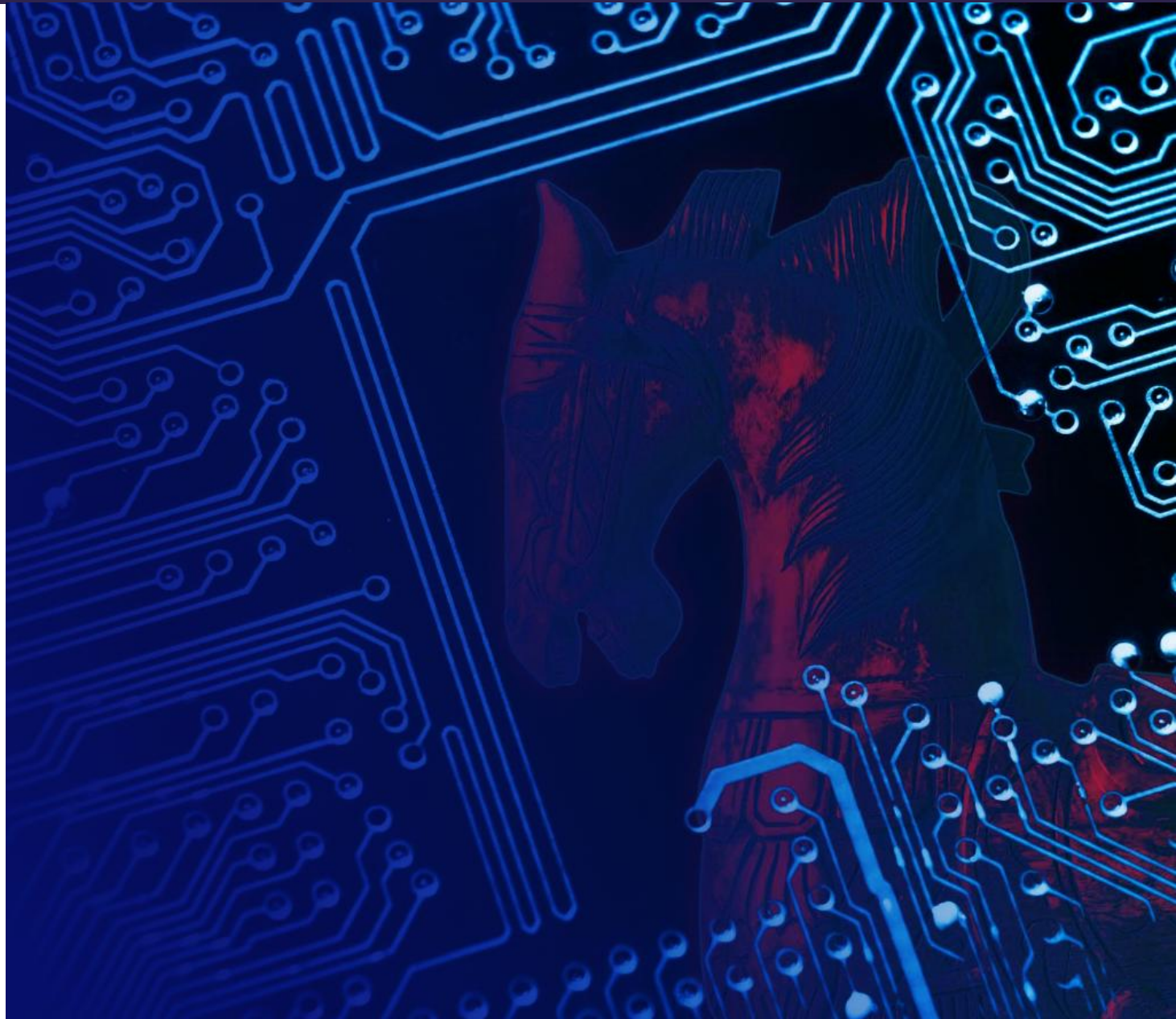
TIPOS DE MALWARE



TROYANO

Este malware lleva a cabo operaciones maliciosas al enmascarar su verdadera intención. **Puede parecer legítimo pero, de hecho, es muy peligroso.** Los troyanos aprovechan sus privilegios de usuario y se encuentran con mayor frecuencia en archivos de imagen, archivos de audio o juegos.

A diferencia de los virus, los troyanos no se replican a sí mismos, sino que actúan como señuelo para colar software malicioso a los usuarios desprevenidos.



TIPOS DE MALWARE



GUSANOS

Este es un tipo de malware que se replica a sí mismo para propagarse de un ordenador a otro. A diferencia de un virus, que requiere un programa anfitrión para ejecutarse, los gusanos pueden ejecutarse por sí mismos. **Aparte de la infección inicial del host, no requieren la participación del usuario y pueden propagarse muy rápidamente por la red.**

Los gusanos comparten patrones similares: aprovechan las vulnerabilidades del sistema, tienen una forma de propagarse y todos contienen código malicioso (carga útil) para dañar los sistemas informáticos o las redes.

Los gusanos son responsables de algunos de los ataques más devastadores en Internet. En 2001, el gusano Code Red había infectado más de 300.000 servidores en solo 19 horas.



PHISHING E INGENIERÍA SOCIAL EL ARTE DEL ENGAÑO

Es un tipo de fraude que tiene por objetivo engañar a la persona usuaria para que **revele algún tipo de información**, generalmente financiera o personal, con el objetivo de suplantar su identidad digital y obtener algún beneficio.

Proviene de la palabra “**fishing**” (pesca), en relación al anzuelo que se le tiende a una persona para que *muerda* (caiga en la trampa).





PHISHING E INGENIERÍA SOCIAL EL ARTE DEL ENGAÑO

Los daños causados por el phishing pueden ser muy variados, y van desde la pérdida de acceso a cuentas de correo electrónico, redes sociales, sitios de compraventa online hasta perjuicios y daños económicos derivados.



PHISHING E INGENIERÍA SOCIAL EL ARTE DEL ENGAÑO

El niño que robó **230.000.000 de dólares**

Un vistazo a uno de los robos de criptomonedas más famosos...

El 19 de agosto de 2024, un grupo de jóvenes adultos organizó uno de los robos de criptomonedas más grandes jamás registrados: robaron más de 230 millones de dólares en bitcoins. Malone Lam, Veer Chetal, Jeandiel Serrano, Danish Khan y Chen no eran piratas informáticos expertos; su robo se llevó a cabo utilizando la naturaleza humana básica.



Fuente:

- https://youtu.be/RMb-FEL78VI?si=stkl-EO_eptYm64I
- https://youtu.be/AzGj5q5Fm80?si=03ifDBZJODi4_c5R

TIPOS DE PHISHING

SEGÚN SU PROPAGACIÓN

POR CORREO ELECTRÓNICO

Modalidad más difundida.

Los mensajes de correo pueden contener enlaces, que dirigen a sitios webs maliciosos, o archivos adjuntos que incluyan un programa o código malicioso (malware).

El **phisher** emite correos, que distribuye en forma masiva, haciéndose pasar por emisores de confianza para la persona usuaria. Generalmente, finge ser alguna entidad bancaria para solicitar información personal de la víctima.

NETFLIX

⚠ Su cuenta está en espera.

Actualice sus detalles de pago

Hola,

Estamos teniendo problemas con su información de facturación actual. Lo intentaremos de nuevo, pero mientras tanto, es posible que desee actualizar sus detalles de pago.

ACTUALIZAR CUENTA AHORA

¿Necesitas ayuda? Estamos aquí si lo necesitas. Visita el [Centro de ayuda](#) o [Contáctenos](#) ahora.

—Tus amigos en Netflix

SHCP
SECRETARÍA DE HACIENDA
Y CREDITO PÚBLICO



SAT
Servicio de Administración Tributaria

Segundo Aviso: 10/12/2015

Estimado Contribuyente:

El **Servicio de Administración Tributaria** se ha percatado que en diversos despachos alrededor del País, Usted ha propuesto esquemas para **evadir el pago de impuestos** y hemos detectado **anomalías en su situación fiscal**. Para evitar una sanción en su contra, Le recomendamos regularizar esta situación de inmediato. A continuación le adjuntamos un documento detallado de su situación fiscal actual.

[Descargar Documento.](#)

© Derechos Reservados SAT - Servicio de Administración Tributaria

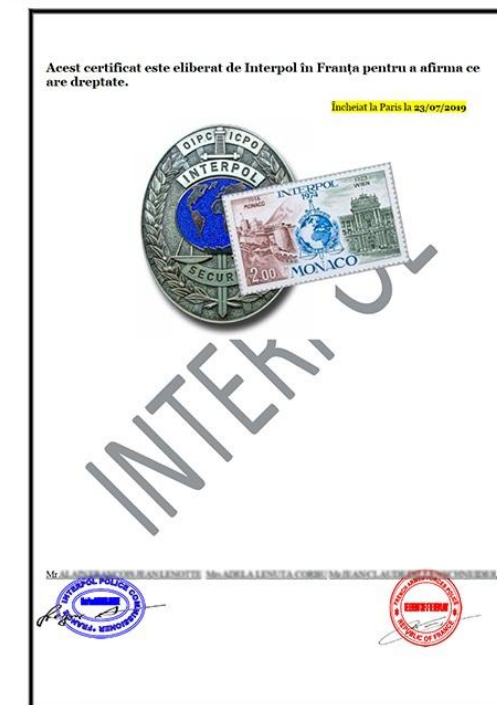
TIPOS DE PHISHING SEGÚN SU PROPAGACIÓN POR CORREO ELECTRÓNICO



Podemos encontrar lo que se conoce como “**estafa nigeriana**”.

El curioso nombre proviene de un “**hoax (bulos informáticos)**” en el que el phisher se hacía pasar por un príncipe nigeriano que decía necesitar una cuenta bancaria para transferir fondos de forma urgente y segura.

Así, la víctima tentada por la obtención de beneficios brindaba datos bancarios al atacante.



Este tipo de phishing ha tenido varias “historias”, algunas tan absurdas como la de un cosmonauta encerrado en una antigua estación espacial rusa durante más de dos décadas, y precisa nuestra ayuda.

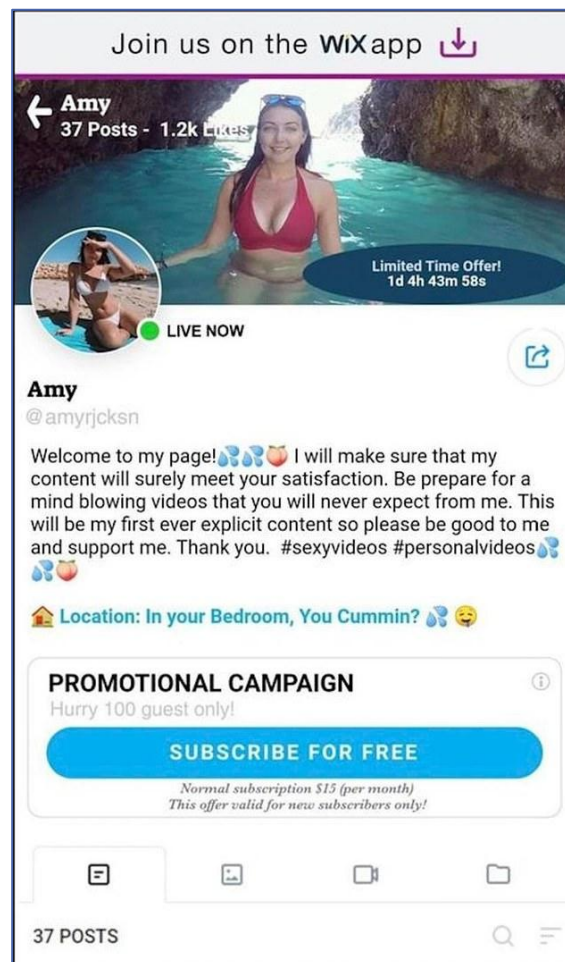
TIPOS DE PHISHING

SEGÚN SU PROPAGACIÓN

POR SITIO WEB

En el phishing por sitio web, el engaño consiste en crear un sitio web que se haga pasar por el original con la intención de que la persona usuaria introduzca sus datos de inicio de sesión.

De esta manera, el phisher se hace con la cuenta de la persona usuaria, pudiendo ser esta de correo, de una entidad financiera o de redes sociales.



En internet existen páginas falsas que pueden robar tu información y defraudarte, anuncian remates y liquidaciones de bienes presuntamente pertenecientes al Gobierno Mexicano, **¡No te dejes engañar!**

Sitio web apócrifo: <https://sat-gob-slp.com>

- ✓ Verifica que navegues en un sitio oficial **.gob.mx**
- ✓ Comprueba con la Policía Cibernética Municipal si la información es válida o real.



TIPOS DE PHISHING

SEGÚN SU PROPAGACIÓN

POR TELÉFONO (VISHING)

El término vishing deviene de “voice phishing”. En este caso, el phisher intenta convencer a su víctima a través del teléfono, ya sea celular o de línea, para que revele información personal que pueda serle de algún provecho.

En este tipo de ataque, el phisher afirma representar a una empresa pública o privada de la cual la persona usuaria es cliente y la amedrenta con algún tipo de problema prometiendo solucionarlo en el momento si se brinda información de cuenta o pagando algún tipo de cargo.



TIPOS DE PHISHING

SEGÚN SU PROPAGACIÓN

POR SMS (SMISHING)

Al igual que en el caso anterior, el término smishing se conforma por una inicial que hace referencia al vector de propagación, en este caso los SMS o servicios de mensajería.

Así, la víctima recibe un mensaje de texto que le solicita que haga clic en un enlace o descargue una aplicación maliciosa. Una vez más, con esta modalidad, se intenta también sorprender a la víctima a través de algún inconveniente inventado para sustraer información valiosa.

A través de WhatsApp se están difundiendo mensajes en la que se ofrecen presuntos empleos por parte de Amazon.

➤ Se trata de una campaña de phishing que busca **tomar el control de tu cuenta.**

- ✓ No hagas clic en este tipo de enlaces.
- ✓ Reporta y bloquea el número desde WhatsApp.
- ✓ Activa la verificación en dos pasos.
- ✓ Verifica que la oferta laboral se encuentre publicada desde una página oficial.

Hola, soy el Director General del proyecto amazon y actualmente estoy reclutando un equipo a tiempo parcial. Puedes hacer trabajos a tiempo parcial con tu teléfono móvil. Un trabajo a tiempo parcial lleva de 10 a 20 minutos. Los recién llegados reciben 68 pesos inmediatamente. Paga diaria: de 1000 a 6380 pesos. Este trabajo requiere una edad mínima de 20 años.

【 Haga clic en el enlace para añadirnos 】 .



12:11 p. m.

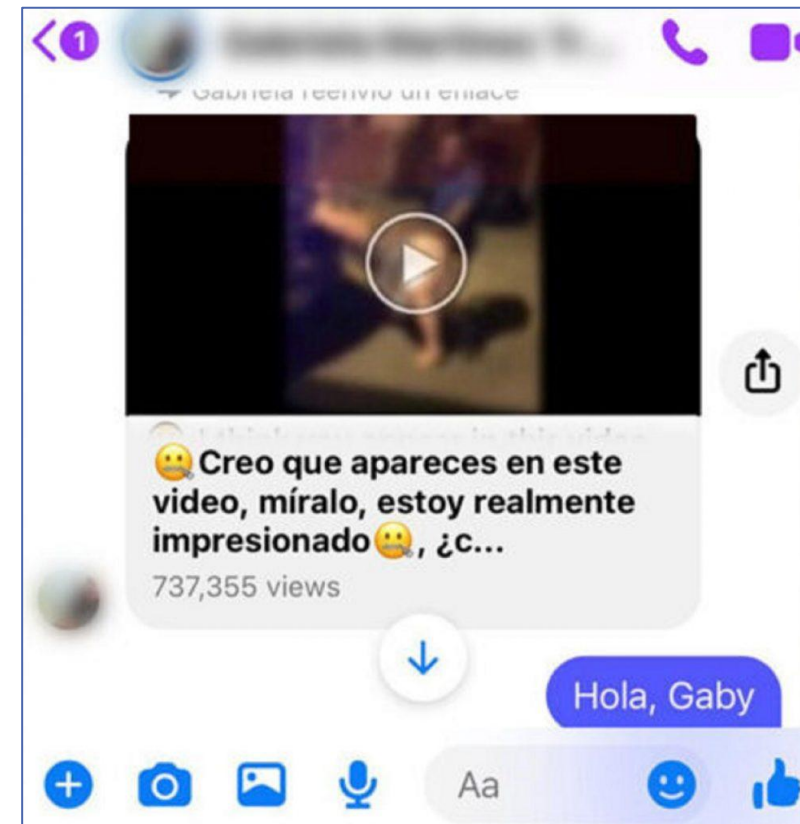
TIPOS DE PHISHING

SEGÚN SU PROPAGACIÓN

POR REDES SOCIALES

El phishing por redes sociales se da en el caso de phishers que acceden a cuentas de redes sociales y logran que la gente envíe enlaces maliciosos o spam a sus contactos, ya sea a través del servicio de mensajería o en el etiquetado de posts públicos.

También es frecuente el robo de datos personales mediante cuentas falsas, a través de las que los hackers logran engañar a sus víctimas.



TIPOS DE PHISHING

SEGÚN SU PROPAGACIÓN

PARA UNA EMPRESA EN PARTICULAR

- SPEAR PHISHING

Si hablamos de pesca, en este caso llamado "spear phishing" se trata de capturar a la víctima con un arpón, que es lo que significa "spear" en el idioma inglés. Consiste en un ataque pensado para una persona física o empresa en particular. La modalidad puede ser variada, pero lo que distingue a este tipo de ataque es su direccionalidad.

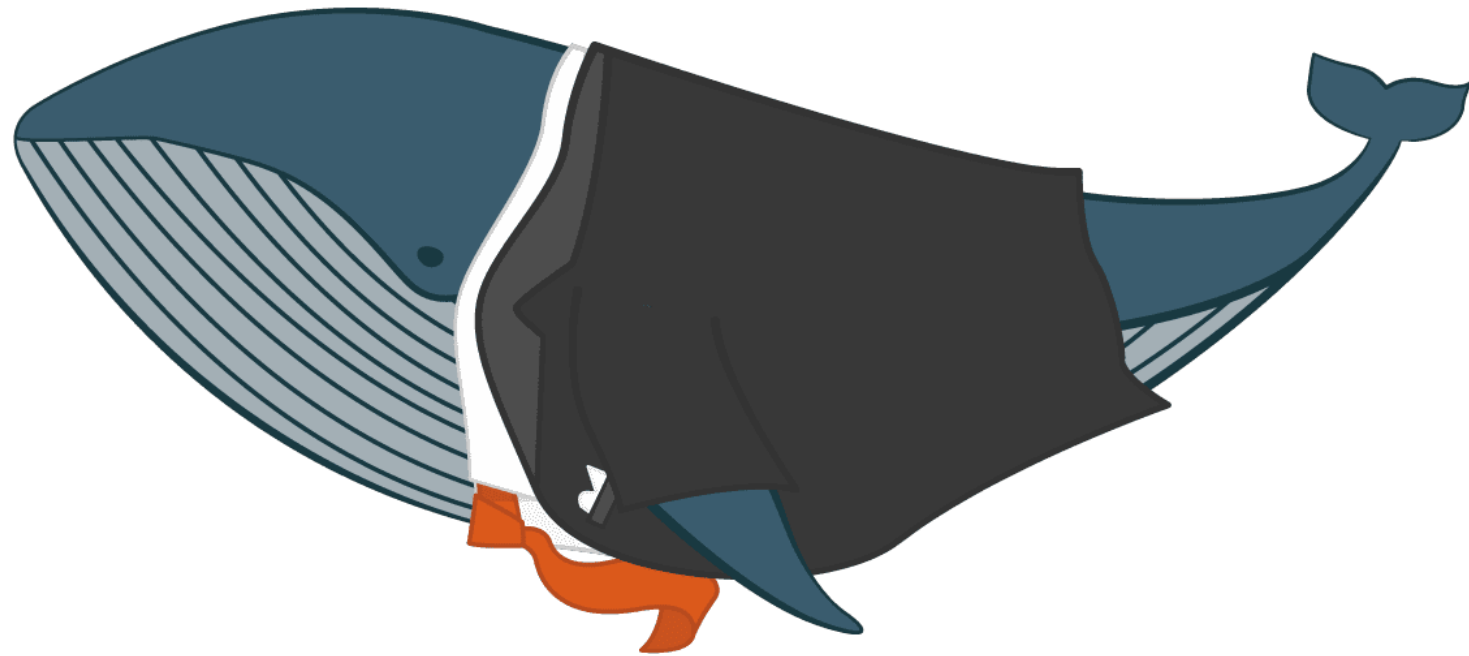
En consecuencia, el modo de contacto con la persona usuaria tenderá a incluir contenido personalizado, lo que lo hace más creíble que un texto genérico. El phisher se hace con información de su objetivo con el fin de ganarse la confianza a través de un ataque más elaborado.



TIPOS DE PHISHING SEGÚN SU PROPAGACIÓN

PARA PERSONAS DE INFLUENCIA - WHALING

Podría decirse que el whaling es un tipo de spear phishing dirigido a “peces gordos”, como ejecutivos de alto rango o **funcionarios de gobierno**.



IDENTIFICAR UN ATAQUE DE PHISHING



Llamada urgente a la acción o amenazas: sospeche de los correos electrónicos que afirman que debe hacer clic, llamar o abrir un archivo adjunto de inmediato. A menudo, afirman que tienes que actuar ahora para reclamar una recompensa o evitar una penalización. **Crear un falso sentido de urgencia es un truco común de los ataques de phishing y estafas.**

Lo hacen para que no piense en ello demasiado o consulte con un asesor de confianza que pueda advertirle.



Remitentes de primera vez o poco frecuentes: aunque no es inusual recibir un correo electrónico de alguien por primera vez, especialmente si están fuera de su organización, esto puede ser un signo de suplantación de identidad (phishing).

Si recibe un correo electrónico de alguien que no reconoce o que Outlook identifica como un remitente nuevo, deténgase un momento para examinarlo con más cuidado.

IDENTIFICAR UN ATAQUE DE PHISHING



Ortografía y mala gramática: las empresas y organizaciones profesionales suelen tener un personal editorial para asegurarse de que los clientes obtienen contenido profesional de alta calidad. Si un mensaje de correo electrónico tiene errores ortográficos o gramaticales obvios, es posible que se trate de una estafa. **Estos errores a veces son el resultado de una traducción incorrecta de otro idioma.** A veces es deliberado, en un intento de sortear filtros que intentan bloquear estos ataques.



Saludos genéricos: una organización que trabaja con usted debe conocer su nombre y, hoy en día, es fácil personalizar un correo electrónico. Si el correo electrónico empieza con un mensaje genérico, como "Estimado señor o señora", es un signo de que puede que no sea realmente su banco o sitio de compras.

IDENTIFICAR UN ATAQUE DE PHISHING



Dominios de correo electrónico que no coinciden: si el correo electrónico dice ser de una empresa acreditada, como Microsoft o su banco, pero el correo electrónico se envía desde otro dominio de correo electrónico como Gmail.com o microsoftsupport.ru probablemente sea una estafa. También esté atento a los errores ortográficos muy sutiles del nombre del dominio legítimo. Como **micros0ft.com** donde la segunda "o" se ha reemplazado por un 0 o rnicrosoft.com, donde la "m" se ha reemplazado por una "r" y una "n". Son trucos comunes de estafadores.



Vínculos sospechosos o datos adjuntos inesperados: si sospecha que un mensaje de correo electrónico es un fraude, no abra los vínculos o datos adjuntos que vea. En su lugar, **pase el mouse sobre el vínculo, pero no haga clic en él**, para ver si la dirección coincide con el vínculo escrito en el mensaje. En el siguiente ejemplo, al colocar el mouse sobre el vínculo se muestra la dirección web real en el cuadro con el fondo amarillo. Tenga en cuenta que la cadena de números no se parece en nada a la dirección web de la empresa.

<https://www.woodgrovebank.com/loginscript/user2.jsp>

http://192.0.2.1/wood/index.htm

RECOMENDACIONES PARA EVITAR CAER EN EL PHISHING

01

Después de leer el **correo no hagas clic en ningún enlace dudoso**. Realiza las verificaciones pertinentes en tu espacio personal de cliente, acudiendo directamente desde la URL del navegador.

02

Mejora la seguridad de su ordenador. El **sentido común** y el buen juicio son tan vitales como mantener tu equipo protegido, pero además, **siempre debes tener las actualizaciones más recientes de tu sistema operativo y navegador web**.

03

Introduce tus datos confidenciales sólo en sitios web seguros. Para que un sitio se pueda considerar como 'seguro', el primer paso -aunque no el único- es que empiece por "https://", sin embargo esto no autentifica que un sitio sea oficial.

RECOMENDACIONES PARA EVITAR CAER EN EL PHISHING

04

Revisa periódicamente tus cuentas. Nunca está de más revisar cada cierto tiempo para estar al tanto de cualquier irregularidad en la actividad.

05

No hagas clic en ventanas emergentes.

06

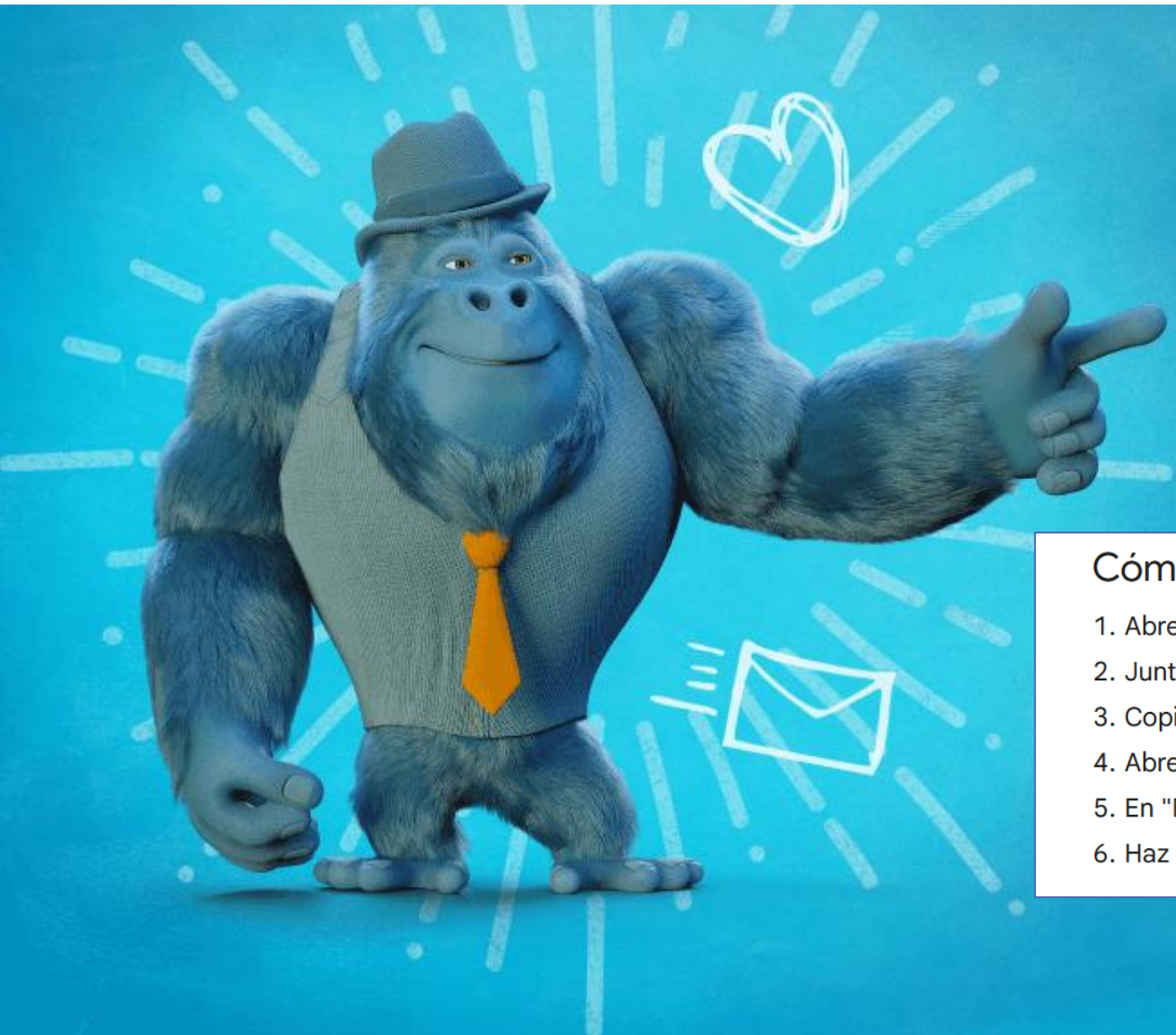
Piense en sus activos digitales con el mismo cuidado con el que se ocupa de su casa y **utilice contraseñas fuertes y diversificadas**, es decir, no use la misma para el correo, la banca personal y otros servicios. También es aconsejable cambiar sus contraseñas con cierta periodicidad. De esta manera, además, evitará uno de los phishing más difundidos: *el presunto mail de proveedor de correo que insta a cambiar la contraseña.*



A VER SI ES CIERTO... EL PHISHING ME LA #3L! ...

<https://phishingquiz.withgoogle.com/>





Bouncer **ofrece una sencilla interfaz de arrastrar y soltar para verificar listas de correo electrónico de hasta 250 000 direcciones.** Identifica los correos electrónicos válidos, desechables y riesgosos, lo que mejora la capacidad de entrega de las campañas y ahorra recursos.

LEER LOS ENCABEZADOS COMPLETOS DE UN CORREO ELECTRÓNICO

<https://support.google.com/mail/answer/29436?hl=es-419>

Cómo leer los encabezados completos de un correo electrónico

1. Abre el correo electrónico cuyos encabezados quieres ver.
2. Junto a Responder ↩, haz clic en Más ⋮ > **Mostrar el original.**
3. Copia el texto de la página.
4. Abre la [Herramienta de encabezados de mensajes](#) .
5. En "Pega el encabezado del correo electrónico aquí", pégalo.
6. Haz clic en **Analizar el encabezado anterior.**

LEER LOS ENCABEZADOS COMPLETOS DE UN CORREO ELECTRÓNICO

<https://support.google.com/mail/answer/29436?hl=es-419>

```
=?us-ascii?Q?XGiDnyQjuBwtuaUlf4C5qv89WIBRJ9NPJQOBYI+i6m6eTf17Q1FSraa+6sRn?=  
=?us-ascii?Q?XQ7YmUmlPa8ewJeroleXmCYzHRqFrCsKkJsF2J385FkLT5/jLILZ7RaH66Bq?=  
=?us-ascii?Q?LYa+OrCJqe/8vLYI9nwUEZ/t6OtEbl9ssqA1qhYrh9FAabH0lw4gLdDFOLic?=  
=?us-ascii?Q?P/dUuhuXZoGR+/HIKGiGRcLSdbCu7JNogQEE6DVUX0NRy7KbjTko3DdDsO8Q?=  
=?us-ascii?Q?ZBJrDCqZdFvvqSRLVw92ZILFQDi3PkcQmCCQUBzglD/gyxhOEw46AUffBW/G?=  
=?us-ascii?Q?gAmHDoTPIf16ZsUW1TMA2s0e/pVv8fbbYUqBG2w7aCc531g8ckmuqB752qcd?=  
=?us-ascii?Q?CMttSG/BcMi3S6v3KqSk1/Km5BEjOqUVY5WQzHKdrTx50/o3cKIMKQ4YkqB?=  
=?us-ascii?Q?VqM2U0sW3FadhV84EEGgsvLI9bVC6qW5VDm9uRK5CXY6qUNPvUnJnsywHbYT?=  
=?us-ascii?Q?sc9dKNEnhb/lg2M4Zz5WZqMbENI5MpQ46shi3QwtlUgONPpsIQOWkpssOht7?=  
=?us-ascii?Q?i21tGqDRkOsfyGEgNOUMXuRQCc2SUFq7Ka0mK1dPpl+0jXXwkpJVmL+sOWAU?=  
=?us-ascii?Q?mKrlMnS1vVfUrZ20xO+S0YZQWuQC5iVEKCYOCP6sFHCNqYknM72hdHsDZZE1?=  
=?us-ascii?Q?7ru2EzzaqprZThn6oWCqr/FQ8xDu5DyBU8ghgzuq/jd4z7VB+JNHI3MXysWf?=  
=?us-ascii?Q?XcjTJV1sxtgMiddnNuYYA4V7s5KkvfkagRo/fzcSGBYAoxmABqH/OF+M+A?=  
=?us-ascii?Q?=3D=3D?=  
X-MS-Exchange-Safelinks-Url-KeyVer: 1
```

← → ↻ https://toolbox.googleapps.com/apps/messageheader/

Google News SSPC Downloader OSINT Crypto Law Enforcement Home CTF Development Uninn

Caja de herramientas de Google Admin Messageheader

Pega la cabecera de un correo electrónico o arrastra y suelta un archivo de texto aquí

ANALIZAR LA CABECERA ANTERIOR

LEER LOS ENCABEZADOS COMPLETOS DE UN CORREO ELECTRÓNICO

<https://support.google.com/mail/answer/29436?hl=es-419>

Aquí tienes un ejemplo del posible aspecto del contenido:

Subject:	Meetups this week with: Board gamers, Finance and others				
SPF:	pass				
DKIM:	pass				

#	Delay	From *		To *	Protocol	Time received
0		mail7.nyi.meetup.com	→	COL004-MC1F51.hotmail.com		4/11/2016, 11:31:44 AM
1	2 sec	COL004-MC1F51.hotmail.com	→	COL004-OMC4S14.hotmail.com		4/11/2016, 11:31:46 AM
2	3 mins	col004-omc4s14.hotmail.com.	→	[Google] mx.google.com	ESMTPS	4/11/2016, 11:34:20 AM
3			→	[Google] 10.98.70.138	SMTP	4/11/2016, 11:34:20 AM
4			→	[Google] 10.103.12.130	SMTP	4/11/2016, 11:34:20 AM

CREANDO UNA CAMPAÑA DE PHISHING

SET (SOCIAL ENGINEER TOOLKIT)

```

Shell No. 1
File Actions Edit View Help

.M""bgd `7MM""`YMM MMP""MM""YMM
,MI  "Y  MM  `7 P'  MM  `7
`MMb.  MM  d      MM
`YMMNq. MMmmMM      MM
.  `MM  MM  Y ,      MM
Mb  dM  MM  ,M      MM
P"Ybmmd" .JMMmmmmMMM .JMMML.

[—] The Social-Engineer Toolkit (SET) [—]
[—] Created by: David Kennedy (ReL1K) [—]
      Version: 8.0.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec [—]
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

```

Select from the menu:

- 1) Spear-Phishing Attack Vectors
- 2) Website Attack Vectors
- 3) Infectious Media Generator
- 4) Create a Payload and Listener
- 5) Mass Mailer Attack
- 6) Arduino-Based Attack Vector
- 7) Wireless Access Point Attack Vector
- 8) QRCode Generator Attack Vector
- 9) Powershell Attack Vectors
- 10) Third Party Modules
- 99) Return back to the main menu.

CREANDO UNA CAMPAÑA DE PHISHING

SET (SOCIAL ENGINEER TOOLKIT)

```

Shell No. 1
File Actions Edit View Help

.M""bgd `7MM""YMM MMP""MM""YMM
,MI  "Y  MM  `7 P'  MM  `7
MMb.   MM  d    MM
`YMMNq. MMmmMM  MM
.  `MM  MM  Y  ,  MM
Mb  dM  MM  ,M  MM
P"Ybmd" .JMMmmmmMM .JMML.

[—] The Social-Engineer Toolkit (SET) [—]
[—] Created by: David Kennedy (ReL1K) [—]
      Version: 8.0.3
      Codename: 'Maverick'
[—] Follow us on Twitter: @TrustedSec [—]
[—] Follow me on Twitter: @HackingDave [—]
[—] Homepage: https://www.trustedsec.com [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

```

```

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

```

```

set> 5

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would
be to send an email to one individual person. The second option
will allow you to import a list and send it to as many people as
you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer

99. Return to main menu.

set:mailer>

```


CREANDO UNA CAMPAÑA DE PHISHING SET (SOCIAL ENGINEER TOOLKIT)

```
set:mailer>1
```

Do you want to use a predefined template or craft a one time email template.

1. Pre-Defined Template
2. One-Time Use Email Template

```
set:phishing>
```

```
set:phishing>1
```

1. Available templates:

- 1: Have you seen this?
- 2: WOAAAAA!!!!!!!!!!!! This is crazy...
- 3: Order Confirmation
- 4: How long has it been?
- 5: Baby Pics
- 6: New Update
- 7: Strange internet usage from your computer
- 8: Dan Brown's Angels & Demons
- 9: Status Report
- 10: Computer Issue

```
set:phishing>
```

```
set:phishing>1
```

```
set:phishing> Send email to: servando.lopez@sspcslp.gob.mx
```

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

```
set:phishing>
```

Shell No. 1

File Actions Edit View Help

- 1: Have you seen this?
- 2: WOAAAAA!!!!!!!!!!!! This is crazy...
- 3: Order Confirmation
- 4: How long has it been?
- 5: Baby Pics
- 6: New Update
- 7: Strange internet usage from your computer
- 8: Dan Brown's Angels & Demons
- 9: Status Report
- 10: Computer Issue

```
set:phishing>1
```

```
set:phishing> Send email to: servando.lopez@sspcslp.gob.mx
```

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

```
set:phishing>2
```

```
set:phishing> From address (ex: moo@example.com): attackermail@domain.com
```

```
set:phishing> The FROM NAME the user will see: GitHub Support
```

```
set:phishing> Username for open-relay [blank]: attackermail
```

```
Password for open-relay [blank]:
```

```
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com): attacker.smtp.com
```

```
set:phishing> Port number for the SMTP server [25]: 25
```

```
set:phishing> Flag this message/s as high priority? [yes/no]: no
```

```
Do you want to attach a file - [y/n]: n
```

```
Do you want to attach an inline file - [y/n]:
```

CREANDO UNA CAMPAÑA DE PHISHING SET (SOCIAL ENGINEER TOOLKIT)

Get started with Gmail



Customize your
inbox



Change profile
image



GitHub Support

Urgent: Login Attempt Detected - Urgent: V

Urgent: Login Attempt Detected Inbox x



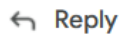
GitHub Support <breachbreakerco@gmail.com>

to me ▾

10:03 AM (19 minutes ago)



Urgent: We have detected a suspicious login attempt on your GitHub account. You need to visit <https://github.com/login> immediately to prevent further access. Please act urgently to secure your account.



Reply



Forward

ACTIVIDAD 04 - Una página demasiado convincente

Objetivo general

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante **Social-Engineer Toolkit (SET)**, utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

Objetivos específicos

Al finalizar la actividad, el alumno deberá ser capaz de:

- Configurar un escenario básico de ingeniería social utilizando **Social-Engineer Toolkit (SET)**.
- Implementar una página web ficticia mediante el módulo **Credential Harvester**.
- Analizar el proceso mediante el cual la información introducida en un formulario web es transmitida y registrada por un servidor.
- Identificar indicadores técnicos y visuales que permitan reconocer una página potencialmente fraudulenta.
- Proponer controles de seguridad orientados a prevenir o reducir el impacto de ataques de phishing.

Duración aproximada:

02 horas y 30 minutos.

Escenario

El área de seguridad informática de una organización ha recibido varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales.

El mensaje contiene un enlace que dirige a un portal aparentemente institucional.

La página incluye logotipo, campos de usuario y contraseña y un mensaje indicando: "Su sesión ha expirado. Inicie sesión nuevamente para continuar."

A primera vista, nada parece fuera de lo común. Sin embargo, el portal **no pertenece a la organización**.

Inicia Social-Engineer Toolkit desde Kali Linux, localiza el módulo: **Credential Harvester Attack Method**.

Agrega capturas al informe y responde.

¿Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing?

Prepara el escenario, para esta actividad se utilizará una página web diseñada específicamente para el laboratorio.

El portal simulará un sistema institucional de autenticación con los siguientes elementos: nombre del sistema, campo de usuario, campo de contraseña, botón de ingreso, mensaje relacionado con la expiración de una sesión.

Después de cargar tu página al modulo de Credential Harvester, abre el navegador en el servidor local y simula el ataque de ingeniería social.

Entrega tu informe, deberá incluir:

1. Portada.
2. Tabla de índice.
3. Objetivo de la actividad.
4. Descripción del escenario.
5. Configuración del laboratorio.
6. Evidencias y descripción del funcionamiento.
7. Explicación del flujo de captura de información.
8. Controles de seguridad propuestos.
9. Conclusión.
10. Referencias.

Durante esta actividad queda prohibido:

- Utilizar páginas pertenecientes a servicios reales.
- Clonar portales de instituciones o empresas.
- Utilizar credenciales personales.
- Solicitar datos a personas ajenas al laboratorio.
- Publicar el servidor hacia Internet.
- Utilizar dominios externos.
- Implementar técnicas de suplantación DNS.
- Instalar payloads.
- Ejecutar código malicioso.

ACTIVIDAD 04 - Una página demasiado convincente

Criterio	Excelente - 2 pts	Bueno - 1 pt	Suficiente - 1 pt	Insuficiente - 0 pts
1. Configuración y ejecución de SET	El programa registra correctamente los eventos en un archivo local y conserva la información después de finalizar la ejecución.	Ejecuta correctamente la simulación, aunque presenta errores menores de configuración que no afectan el resultado final.	Logra ejecutar parcialmente la práctica o requiere correcciones importantes para que SET funcione correctamente.	No logra configurar o ejecutar la simulación solicitada.
2. Evidencias de la práctica	Presenta las evidencias completas, claras, ordenadas y suficientes para comprobar cada etapa realizada.	Presenta la mayoría de las evidencias y permiten comprobar el desarrollo de la práctica, aunque alguna es incompleta o poco clara.	Presenta evidencias parciales que únicamente permiten comprobar algunas etapas de la práctica.	No presenta evidencias suficientes para comprobar la realización de la actividad.
3. Análisis del funcionamiento del ataque	Explica correctamente el recorrido de la información desde el formulario hasta SET, identificando la petición HTTP, el servidor y el registro de parámetros, y distingue claramente entre captura de credenciales y vulneración de una contraseña.	Explica correctamente el funcionamiento general de la simulación, aunque omite o desarrolla superficialmente alguno de los elementos técnicos.	Describe de manera general lo ocurrido, pero presenta confusiones sobre el funcionamiento técnico o el papel desempeñado por SET.	No explica el funcionamiento de la simulación o presenta una interpretación técnicamente incorrecta.
4. Identificación de indicadores y medidas de protección	Identifica al menos cinco indicadores relevantes de phishing y propone cinco controles de seguridad correctamente justificados, explicando sus alcances y limitaciones.	Identifica los indicadores y controles solicitados, aunque algunas justificaciones son poco desarrolladas o presentan pequeñas imprecisiones.	Identifica parcialmente los indicadores o controles solicitados y ofrece explicaciones generales con poca justificación.	No identifica adecuadamente los indicadores de phishing ni propone controles pertinentes.
5. Reporte, diagrama y conclusión	Entrega un reporte completo, organizado y técnicamente coherente; el diagrama representa correctamente el flujo de la simulación y la conclusión demuestra comprensión de los riesgos de ingeniería social.	El reporte cumple con la estructura solicitada y presenta un análisis adecuado, aunque existen omisiones menores en el diagrama, organización o conclusión.	El reporte cumple con la estructura solicitada y presenta un análisis adecuado, aunque existen omisiones menores en el diagrama, organización o conclusión.	El reporte está incompleto, carece del diagrama solicitado o no presenta una conclusión relacionada con los aprendizajes de la actividad.